broader scope of customer information than many states;[23] providing for a 30-day notification deadline that is shorter than the timing currently mandated by many states (including states that have no deadline or those allowing for various notification delays);[24] and providing for a more robust notification trigger than in many states.[25]

Commenters also raised concerns with differences between the proposed amendments and other Federal regulators' safeguarding standards that also include a requirement for a data breach response plan or program.[26] The GLBA and FACT Act oblige us to adopt regulations, to the extent possible, that are consistent and comparable with those adopted by the Banking Agencies, the Consumer Financial Protection Bureau ("CFPB"), and the FTC.[27] Accordingly, the Commission has also been mindful of the need to set standards for safeguarding customer records and information that are consistent and comparable with the corresponding standards set

---

23 *See infra* section IV.D.1.b(3).

24 *See infra* section IV.D.1.b(2).

25 *See infra* section IV.D.1.b(4).

26 The Federal Trade Commission ("FTC") in 2021 amended its Safeguards Rule (16 CFR part 314 ("FTC Safeguards Rule")) by, among other things, adding a requirement for financial institutions under the FTC's GLBA jurisdiction to establish a written incident response plan designed to respond to information security events. *See* FTC, Standards for Safeguarding Customer Information, 86 FR 70272 (Dec. 9, 2021). As amended, the FTC's rule requires that a response plan address security events materially affecting the confidentiality, integrity, or availability of customer information in the financial institution's control, and that the plan include specified elements that would include procedures for satisfying an institution's independent obligation to perform notification as required by state law. *See id.* at n.295. The "Banking Agencies" include the Office of the Comptroller of the Currency ("OCC"), the Board of Governors of the Federal Reserve System ("FRB"), the Federal Deposit Insurance Corporation ("FDIC"), and the former Office of Thrift Supervision. In 2005, the Banking Agencies and the National Credit Union Administration ("NCUA") jointly issued guidance on responding to incidents of unauthorized access to or use of customer information. *See* Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice, 70 FR 15736 (Mar. 29, 2005) ("Banking Agencies' Incident Response Guidance"). The Banking Agencies' Incident Response Guidance provides, among other things, that when an institution becomes aware of an incident of unauthorized access to sensitive customer information, the institution should conduct a reasonable investigation to determine promptly the likelihood that the information has been or will be misused. If the institution determines that misuse of the information has occurred or is reasonably possible, it should notify affected customers as soon as possible.

27 *See generally* 15 U.S.C. 6804(a) (directing the agencies authorized to prescribe regulations under title V of the GLBA to assure to the extent possible that their regulations are consistent and comparable); 15 U.S.C. 1681w(a)(2)(A) (directing the agencies with enforcement authority set forth in 15 U.S.C. 1681s to consult and coordinate so that, to the extent possible, their regulations are consistent and comparable).

by these agencies in developing the amendments.[28] To this end, we have modified the final amendments from the proposal to promote greater consistency with other applicable Federal safeguard standards to the extent they do not affect the investor protection purposes of this rulemaking, as discussed in more detail below. For example, the final amendments require covered institutions to ensure that their service providers provide notification as soon as possible, but no later than 72 hours after becoming aware that an applicable breach has occurred, which is informed by the 72-hour deadline that is required under the Cyber Incident Reporting for Critical Infrastructure Act of 2022 ("CIRCIA").[29]

We recognize, however, that there are some areas of divergence between the final amendments and other Federal regulators' GLBA safeguarding standards, and we discuss the basis for each provision of the final rules below, including cases where the amendments differ from analogous requirements under state law or other federal regulations.[30]

Many commenters also urged the Commission to coordinate with other Federal agencies, particularly on reporting deadlines.[31] For example, a number of commenters suggested that the Commission coordinate with CISA as it develops regulations pursuant to CIRCIA.[32] We have

---

28 *See* Proposing Release at the text following n.37.

29 *See* final rule 248.30(a)(5)(i); *see also infra* footnote 245 and accompanying text (discussing how a 72-hour reporting deadline would align with other regulatory standards). Under CIRCIA, the 72-hour reporting deadline is for entities to report cyber incidents to the Cybersecurity and Infrastructure Security Agency ("CISA").

30 Among the changes being adopted, we are revising as proposed the requirements of 17 CFR 248.17 ("rule 248.17") to refer to determinations made by the CFPB rather than the FTC, consistent with changes made to section 507 of the GLBA by the Dodd-Frank Wall Street Reform and Consumer Protection Act. *See* Pub. L. 111-203, sec. 1041, 124 Stat. 1376 (2010). Upon its adoption, rule 248.17 essentially restated the then-current text of section 507 of the GLBA, and as such, referenced determinations made by the FTC. *See* Privacy of Consumer Financial Information (Regulation S-P), Exchange Act Release No. 42974 (June 22, 2000) [65 FR 40334 (June 29, 2000)].

31 *See*, *e.g.*, Comment Letter of Amazon Web Services (June 5, 2023) ("AWS Comment Letter"); Comment Letter of Google Cloud (June 5, 2023) ("Google Comment Letter"); and Nasdaq Comment Letter.

32 *See*, *e.g.*, SIFMA Comment Letter 2; Cambridge Comment Letter; Google Comment Letter. CISA has

consulted and coordinated with CISA and, consistent with the requirements of the GLBA and other statutory requirements,[33] other relevant agencies and their representatives for the purpose of ensuring, to the extent possible, that the amendments are consistent and comparable with the regulations prescribed by other relevant agencies.[34]

We are adopting amendments to Regulation S-P substantially as proposed, with some changes in response to comments. The principal elements of the final amendments, as discussed in more detail below, are as follows:

- *Incident Response Program.* The final safeguards rule requires covered institutions to develop, implement, and maintain written policies and procedures for an incident response program that is reasonably designed to detect, respond to, and recover from unauthorized access to or use of customer information. The final amendments will require that a response program include procedures to assess the nature and scope of any incident and to take appropriate steps to contain and control the incident to prevent further unauthorized access or use.
- *Notification Requirement.* The response program procedures in the final amendments also includes a requirement that covered institutions provide a notification to individuals whose sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization. Notice

provided a notice of proposed rulemaking that would implement the CIRCIA requirements but they have not yet been adopted. *See also* Cyber Incident Reporting for Critical Infrastructure Act (CIRCIA) Reporting Requirements, 89 FR 23644 (Apr. 4, 2024).

33 *See* Exchange Act Section 17A(d)(3)(A), 15 U.S.C 78q-1(d)(3)(A) (providing that "[w]ith respect to any clearing agency or transfer agent for which the Commission is not the appropriate regulatory agency, the Commission and the appropriate regulatory agency for such clearing agency or transfer agent shall consult and cooperate with each other...").

34 *See* 15 U.S.C. 6804(a)(2). The relevant agencies include the OCC, FRB, FDIC, CFPB, FTC, CISA, Commodity Futures Trading Commission ("CFTC"), Department of Justice ("DOJ"), and the National Association of Insurance Commissioners.

will not be required if a covered institution determines, after a reasonable investigation of the facts and circumstances of the incident of unauthorized access to or use of sensitive customer information, that the sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience. Under the final amendments, a customer notice must be clear and conspicuous and provided by a means designed to ensure that each affected individual can reasonably be expected to receive it. This notice must be provided as soon as reasonably practicable, but not later than 30 days, after the covered institution becomes aware that unauthorized access to or use of customer information has, or is reasonably likely to have, occurred. As discussed in more detail below, the final amendments will permit covered institutions to delay providing notice after the Commission receives a written request from the Attorney General that this notice poses a substantial risk to national security or public safety.[35]

- *Service Providers.* The final amendments to the safeguards rule include new provisions that address the use of service providers by covered institutions. Under these provisions, covered institutions will be required to establish, maintain, and enforce written policies and procedures reasonably designed to require oversight, including through due diligence and monitoring of service providers, including to ensure that affected individuals receive any required notices. The final amendments make clear that while covered institutions may use service providers to provide any required notice, covered institutions will retain the obligation to

[35] *See infra* section II.A.3.d(2).

ensure that affected individuals are notified in accordance with the notice requirements.

- *Scope.* The final amendments will more closely align the information protected under the safeguards rule and the disposal rule by applying the protections of both rules to "customer information," a newly defined term. The final amendments will also broaden the group of customers whose information is protected under both rules. Also, transfer agents will be required to comply with the safeguards rule.
- *Recordkeeping and Annual Notice Amendments.* The final amendments will add requirements for covered institutions, other than funding portals,[36] to make and maintain written records documenting compliance with the requirements of the safeguards rule and the disposal rule. Further, the final amendments amend the existing requirement to provide annual privacy notices to codify a statutory exception.

II. DISCUSSION

Since Regulation S-P was first adopted in 2000, evolving digital communications and information storage tools and other technologies have made it easier for firms to obtain, share, and maintain individuals' personal information. This increases the risk of customers' information being accessed or used without authorization, for example in a cyberattack or if customer information is improperly disposed of or stolen. In particular, as a frequently-targeted industry, the financial sector has observed increased exposure to cyberattacks that threaten not only the financial firms themselves, but also their customers, especially considering that customer records

[36] As discussed below, funding portals are already subject to recordkeeping requirements with regard to documenting their compliance with Regulation S-P, which are not being amended by these final amendments. *See infra* footnote 385 and accompanying discussion.

and other information that covered institutions possess can be particularly sensitive.[37] The final amendments will modernize and enhance the protections that Regulation S-P already provides to address this changed landscape.

A. Incident Response Program Including Customer Notification

As set forth in the proposal, security incidents may result in, among other things, misuse, exposure or theft of a customer's nonpublic personal information, and potentially leave affected individuals vulnerable to having their information further compromised. Threat actors can use customer information to cause harm in a number of ways, such as by stealing customer identities to sell to other threat actors on the dark web, publishing customer information on the dark web, using customer identities to carry out fraud themselves, or taking over a customer's account for malevolent purposes.

To help protect against harms that may result from a security incident involving customer information, the Commission proposed and is adopting amendments to the safeguards rule largely as proposed, with certain modifications to the notification requirement as discussed further below.[38] The amendments will require that covered institutions' safeguards policies and procedures include an incident response program for unauthorized access to or use of customer information, including customer notification procedures.[39] The amendments will require the incident response program to be reasonably designed to detect, respond to, and recover from both unauthorized access to and unauthorized use of customer information (for the purposes of this

---

37 *See infra* section IV.C.1.

38 *See infra* section II.A.3.

39 *See* final rule 248.30(a)(3). For clarity, when the amendments to the safeguards rule refer to "unauthorized access to or use", the word "unauthorized" modifies both "access" and "use."

release, an "incident").[40] Any instance of unauthorized access to or use of customer information will trigger a covered institution's incident response program. The amendments will also require that the response program include procedures for notifying affected individuals whose sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization.[41]

In this regard, requiring covered institutions to have incident response programs will help mitigate the risk of harm to affected individuals stemming from incidents where a customer's information has been accessed or used without authorization. For example, incident response programs will help covered institutions to be better prepared to respond to such incidents, and providing notice to affected individuals will aid those individuals in taking protective measures that could mitigate harm that might otherwise result from unauthorized access to or use of their information. Further, a reasonably designed incident response program will help facilitate more consistent and systematic responses to customer information security incidents and help avoid inadequate responses based on a covered institution's initial impressions of the scope of the information involved in the compromise. Requiring the incident response program to address any incident involving customer information can help a covered institution better contain and control these incidents and facilitate a prompt recovery.

As proposed, the amendments will require that a covered institution's incident response program include policies and procedures containing certain general elements but will not

---

40 *See* final rule 248.30(a)(3). *See also infra* section II.B.1 for a discussion of "customer information."

41 *See* final rule 248.30(d)(9) for the definition of "sensitive customer information." *See also infra* section II.A.3.b, which includes a discussion of "sensitive customer information." Notice must be provided unless a covered institution determines, after a reasonable investigation of the facts and circumstances of the incident of unauthorized access to or use of sensitive customer information that occurred at the covered institution or one of its service providers that is not itself a covered institution, that sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience.

prescribe specific steps a covered institution must undertake when carrying out incident response activities, thereby enabling covered institutions to create policies and procedures best suited to their particular circumstances. Specifically, a covered institution's incident response program will be required to have written policies and procedures to:

(i) Assess the nature and scope of any incident involving unauthorized access to or use of customer information and identify the customer information systems and types of customer information that may have been accessed or used without authorization;[42]

(ii) Take appropriate steps to contain and control the incident to prevent further unauthorized access to or use of customer information;[43] and

(iii) Notify each affected individual whose sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization in accordance with the notification obligations discussed below,[44] unless the covered institution determines, after a reasonable investigation of the facts and circumstances of the incident of unauthorized access to or use of sensitive customer information, that the sensitive customer information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience.[45]

---

42 *See* final rule 248.30(a)(3)(i). The term "customer information systems" would mean the information resources owned or used by a covered institution, including physical or virtual infrastructure controlled by such information resources, or components thereof, organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of customer information to maintain or support the covered institution's operations. *See* final rule 248.30(d)(6).

43 *See* final rule 248.30(a)(3)(ii).

44 *See* i*nfra* section II.A.3.

45 *See* final rule 248.30(a)(3)(iii).

The Commission received multiple comments regarding the proposed requirement for an incident response program generally.[46] One commenter supported requiring the incident response program and appreciated its similarity to the Banking Agencies' Incident Response Guidance.[47] Another commenter stated that there should not be a one-size-fits-all approach to incident response programs, stating that an adviser should have discretion to determine how the incident response program should be implemented, and requested that any final rule make clear that specific steps for incident response are not required.[48] Moreover, this commenter requested that the final rule expressly indicate that in developing their programs, advisers should employ a principles- and risk-based approach.[49] This commenter also opposed the addition of any requirement in the policies and procedures for an adviser to designate an employee with specific qualifications and experience (or hire a similarly qualified third party) to coordinate its incident response program.[50]

Covered institutions need the flexibility to develop policies and procedures suited to their size and complexity and the nature and scope of their activities. Therefore, we did not propose, and are not adopting, specific steps a covered institution must take when carrying out its incident response program, and we are not specifically designating who must undertake oversight responsibilities, thus providing covered institutions flexibility to determine whether and how to appropriately assign or divide such responsibilities. As proposed and adopted, the amendments

---

46 Comments for specific components of the incident response program are discussed in more depth separately. *See infra* sections II.A.1-4.

47 *See* ICI Comment Letter 1; *see also supra* footnote 26 (discussing the Banking Agencies' Incident Response Guidance).

48 *See* IAA Comment Letter 1.

49 *See id.; see also* CAI Comment Letter stating that policies and procedures should be based on the specific risks of the particular covered institution and commensurate with the size and complexity of the covered institution's activities.

50 *See id.*

will require that a covered institution's incident response program include policies and procedures containing certain general elements, so covered institutions may tailor their policies and procedures to their individual facts and circumstances. Additionally, advisers, like other covered institutions, can continue to use a risk-based approach to tailor their assessment and containment policies and procedures if they choose to do so, as long as the required elements of the incident response program are met.

Two commenters opposed the scope of the proposed incident response program.[51] Specifically, these commenters stated that, consistent with the notification requirements, the assessment and containment and control components of the incident response program should be limited to sensitive customer information (and not encompass all nonpublic customer information).[52] According to one commenter, because sensitive customer information is the information likely to cause substantial harm or inconvenience to a customer and that requires notification to customers, it follows that incident response programs should be tailored to sensitive customer information.[53] The other commenter stated that clients would view the protection of their sensitive customer information as a critically important aspect of their relationship with their adviser and that an adviser's efforts and resources should appropriately be focused on this information.[54]

We are adopting as proposed final rules which require the incident response program's assessment and containment and control components to cover a broader scope of information than the notification requirements. The scope of information covered by the assessment and

---

51 *See* Comment Letter of Schulte Roth & Zabel LLP (June 5, 2023) ("Schulte Comment Letter") and IAA Comment Letter 1.

52 *See* Schulte Comment Letter; IAA Comment Letter 1.

53 *See* Schulte Comment Letter.

54 *See* IAA Comment Letter 1.